

MISSION PROFESSIONNELLE

Analyse de risques : PROJET PAPERLESS Méthodologie EBIOS Risk Manager(ANSSI – 2018)

Client : **Hôpital Sainte-Marie Laboratoire Bioclinique (HSM-Bioclinique)**

Cabinet prestataire : **NovaSec Consulting**

Version : **1.1**

Confidentialité : **Confidentiel – Usage interne**

Auteurs / consultants :

- **Loïc YAMGA** – Chef de mission / Lead cybersécurité & méthodologie EBIOS-RM
- **Samuel KISSI-BI** – Consultant Audit technique & infrastructure
- **Céline NINKE** – Consultante Conformité / RGPD / Gouvernance
- **Keren ADAMU** – Consultante AMOA / Processus métiers & organisation
- **Urich TAMO OUOGUE** – Analyste sécurité / Inventaires & vulnérabilités

ANALYSE DE RIQUES EBIOS RM

PROJET PAPERLESS RH

TABLE DE MATIERES

Table de matières

1. Préambule.....	3
2. Méthodologie utilisée	3
3. Légende – Échelle de gravité ANSSI (référentiel unique du document).....	4
4. Atelier 1 – Cadrage & périmètre	4
5. Atelier 2 – Événements redoutés (ER).....	4
6. Atelier 2 – Sources de risques (SR) & Objectifs visés (OV).....	5
7. Atelier 3 – Scénarios stratégiques (SS)	5
8. Atelier 4 – Scénarios opérationnels (SO)	5
9. Atelier 5 – Appréciation des risques.....	6
10. Traitement des risques	6
11. Exigences de sécurité – Matrice EXI ↔ Risque.....	6
12. Référentiels applicables – Pyramide.....	7
13. Valeurs métier et biens supports	7
14. Cartographies	7
15. Types d’impacts.....	8

ANALYSE DE RIQUES EBIOS RM

PROJET PAPERLESS RH

1. Préambule

Ce document présente l'analyse de risques réalisée selon la méthodologie EBIOS Risk Manager (ANSSI – 2018) dans le cadre du projet Paperless RH, visant la digitalisation et la sécurisation des bulletins de paie, incluant un coffre-fort numérique et l'intégration au SIRH existant de l'hôpital HSM-Bioclinique

1. Rappel du contexte du projet (Résumé court)

Le projet Paperless RH consiste à remplacer l'émission papier des bulletins de salaire par un processus entièrement numérique et sécurisé incluant :

- Un SIRH central pour la génération des bulletins ;
- Un coffre-fort numérique pour la conservation probante ;
- Un portail salarié permettant la consultation sécurisée ;
- Un flux automatisé entre la paie, le SIRH et le coffre-fort.

Les enjeux majeurs identifiés sont :

- Confidentialité élevée des données de paie (données sensibles).
- Conformité RGPD, eIDAS, PGSSI-S.
- Traçabilité et preuve d'intégrité des bulletins.
- Disponibilité du SIRH pour éviter tout retard de paie.

2. Méthodologie utilisée

2.1 EBIOS-RM – ANSSI (2018)

Les cinq ateliers sont appliqués :

1. Atelier 1 – Cadrage
2. Atelier 2 – Sources de risques (SR)
3. Atelier 3 – Scénarios stratégiques (SS)
4. Atelier 4 – Scénarios opérationnels (SO)
5. Atelier 5 – Traitement & appréciation du risque

2.2 Avantages

- Approche structurée (ANSSI)
- Vision macro (SS) et micro (SO)
- Alignée RGPD – ISO 27001 – PGSSI-S
- Adaptée à la dématérialisation RH

ANALYSE DE RIQUES EBIOS RM

PROJET PAPERLESS RH

3. Légende – Échelle de gravité ANSSI (référentiel unique du document)

Niveau	Gravité	Description
1	Mineur	Impact faible
2	Significatif	Impacts localisés
3	Majeur	Perturbation importante
4	Critique	Atteinte forte ou prolongée
5	Catastrophique	Compromission totale

- Cette échelle est utilisée dans ER, SS, SO, risques, exigences.
- Critères considérés : Confidentialité, Intégrité, Disponibilité, Traçabilité (C-I-D-T).

4. Atelier 1 – Cadrage & périmètre

Le périmètre fonctionnel, technique et organisationnel est défini dans le document de cadrage du projet.

Référence : Document de cadrage – Projet Paperless RH (Version validée par HSM).

5. Atelier 2 – Événements redoutés (ER)

ER	Description	Impact métier	Commentaire	Gravité (1-5)
ER1	Perte / fuite d'un bulletin de paie	Confidentialité	Données sensibles RH	4
ER2	Altération d'un bulletin	Intégrité	Affecte confiance & conformité	3
ER3	Indisponibilité du SIRH	Disponibilité	Retard paie, blocage RH	4
ER4	Absence de preuve	Traçabilité	Risque juridique & probatoire	5
ER5	Compromission d'un accès RH	C+I+D	Accès indus, risque maximal	5

ANALYSE DE RIQUES EBIOS RM

PROJET PAPERLESS RH

6. Atelier 2 – Sources de risques (SR) & Objectifs visés (OV)

SR	Source de risque	Nature	Objectif visé	Motivation	Gravité
SR1	Cybercriminel	Externe	OV1 : vol données RH	Gain financier	5
SR2	Agent interne malveillant	Interne	OV2 : modifier fiche de paie	Avantage personnel	4
SR3	Erreur humaine	Interne	OV3 : corruption / effacement	Involontaire	3
SR4	Prestataire négligent	Externe	OV4 : exposition / altération	Faible hygiène	4
SR5	Défaillance technique	Système	OV5 : indisponibilité SIRH	Aléatoire	3

7. Atelier 3 – Scénarios stratégiques (SS)

(SR + ER = Risque stratégique)

SS	Source	ER associé	Voie d'attaque	Gravité	Commentaire
SS1	SR1	ER1	Exploitation faille SIRH	5	Critique
SS2	SR2	ER2	Abus de privilèges	4	Risque réel
SS3	SR4	ER4	Solution coffre-fort non qualifiée	4	Conformité eIDAS
SS4	SR3	ER3	Manipulation erronée	3	Fréquent
SS5	SR5	ER3	Panne / corruption	4	Technique

8. Atelier 4 – Scénarios opérationnels (SO)

(Kill chain, vulnérabilités, impact C-I-D-T)

ANALYSE DE RIQUES EBIOS RM PROJET PAPERLESS RH

SO	Scénario stratégique	Kill chain	Vulnérabilités	Impact	Gravité	Probabilité
SO1	SS1	Recon → Exploit → Exfiltration	MFA absent, patchs manquants	Conf	5	3
SO2	SS2	Abus accès interne	Habilitations faibles	Intégrité	4	4
SO3	SS3	prestataire	SLA insuffisant	Conformité	4	3
SO4	SS4	manipulation	Absence de procédure	Disp	3	4

9. Atelier 5 – Appréciation des risques

Gravité	Probabilité	Criticité	Niveau
5	4	20	Critique
4	4	16	Critique
4	3	12	Majeur
3	4	12	Majeur
3	3	9	Significatif

10. Traitement des risques

Risque	Criticité	Traitement	Actions	Responsable
SO1	20	Réduction	MFA, patching, segmentation	DSI
SO2	16	Réduction	IAM renforcé, POLP	RH + DSI
SO3	12	Évitement	Choix coffre-fort qualifié	Achats
SO4	12	Réduction	Formation, procédures	RH

11. Exigences de sécurité – Matrice EXI ↔ Risque

Exigence	Référentiel	Risque	Sévérité	Priorité
EXI1 MFA	ISO 27001 A.9	SO1	5	Haute
EXI2 Journalisation	PGSSI-S	SO3	4	Haute
EXI3 Coffre-fort qualifié	eIDAS	SS3	4	Haute
EXI4 Gestion des habilitations	RGPD	SO2	4	Haute
EXI5 Sensibilisation RH	RGPD Art.32	SO4	3	Moyenne

ANALYSE DE RIQUES EBIOS RM

PROJET PAPERLESS RH

12. Référentiels applicables – Pyramide

Niveau	Référentiels
Haut	DORA, NIS2
Moyen	RGPD, ISO 27001
Bas	PCIDSS, ACPR, PGSSI-S

13. Valeurs métier et biens supports

Valeur métier	Bien support
Données clients	CRM, BD
Transactions bancaires	Système de paiement
Identité numérique	AD, IAM

14. Cartographies

- Cartographie des données sensibles RH

Traitement RH / Processus	Description	Objectif	Commentaires / Risques
Distribution des fiches de paie	Transmission des bulletins aux salariés	Zéro papier, traçabilité	Actuellement papier, risque perte/fuite, pas de traçabilité
Archivage RH	Conservation des bulletins et documents RH	Conformité réglementaire et traçabilité	Archivage papier non sécurisé, risque incendie/perte
Gestion des identités et habilitations	Gestion des accès et droits via AD / Azure AD	Sécurisation des accès	MFA non généralisé, segmentation insuffisante
Gestion des contrats et rémunérations	Saisie, modification et suivi des contrats et salaires	Respect des obligations légales et RH	SIRH non audité depuis 3 ans, risque d'altération des données
Processus RH général (workflow, notifications)	Processus de validation, notifications, suivi des salariés	Optimisation des processus	Non documenté, hétérogénéité des pratiques, erreurs possibles

- Cartographie des traitements Paperless RH

ANALYSE DE RIQUES EBIOS RM

PROJET PAPERLESS RH

Flux / Support numérique	Processus associé	Type de flux	Commentaires / Risques
Coffre-fort numérique (futur)	Distribution et archivage des bulletins	Flux sécurisé, stockage	Solution non encore déployée, risque de non-conformité eIDAS
SIRH	Gestion des contrats, salaires, paie	Flux applicatif interne	Pas d'audit récent, risque altération données
Portail salarié / intranet RH	Consultation bulletins, notifications	Flux interne web	Accès contrôlé nécessaire, MFA partiel
Email sécurisé / notifications	Transmission de notifications RH	Flux externe / interne	Risque interception si chiffrement insuffisant
AD / Azure AD, SSO, MFA	Authentification, gestion des accès	Flux d'identité et d'habilitations	MFA non généralisé, risque accès non autorisé

- Cartographie des flux paperless RH

15. Types d'impacts

Impact	Exemple
Gouvernance	Processus RH
Financier	Pénalités
Juridique	RGPD
Image	Confiance interne